

# Password & Authentication Policy

## 1. Purpose

This policy defines requirements for creating, managing, protecting, and rotating passwords and authentication credentials across all Summit IT Services systems. Strong credential hygiene is the first line of defense against unauthorized access, account compromise, and data breaches. This policy leverages Summit IT's deployment of 1Password Business as the enterprise password manager and Okta as the primary identity provider.

## 2. Scope

This policy applies to:

- All employees, contractors, temporary workers, and service accounts with access to Summit IT Services systems.
- All credentials used to authenticate to Summit IT Services systems, including Okta, Microsoft 365, Slack, Zoom, SummitDesk, 1Password, CrowdStrike, Intune, Jamf Pro, AWS, and any SaaS or internally hosted application.
- Service accounts, API keys, and shared credentials.
- Local administrator accounts on Windows 11 and macOS endpoints.

## 3. Policy Statements

### 3.1 Password Manager Requirements

3.1.1 All employees must use **1Password Business** as their primary credential vault for all work-related accounts. Personal passwords must not be stored in 1Password Business vaults.

3.1.2 Every employee's 1Password account is provisioned via Okta and must be accessed using SSO. Emergency kit (secret key + master password) must be stored offline in a physically secure location known only to the employee.

3.1.3 Shared credentials (team vaults, service accounts) must be stored in 1Password shared vaults with access granted through defined 1Password groups. Sharing credentials outside of 1Password (email, Slack, sticky notes) is prohibited.

3.1.4 1Password must be used to generate unique, random passwords for every new account. Employees must not reuse passwords across different services.

### 3.2 Password Complexity and Length

The following minimum standards apply to user-created passwords (including the Okta master password and local device PINs). Where 1Password generates passwords, it must be configured to meet or exceed

these minimums:

| Account Type                                | Minimum Length                     | Complexity Requirements                             |
|---------------------------------------------|------------------------------------|-----------------------------------------------------|
| Okta (SSO master)                           | 16 characters                      | Upper + lower + digit + symbol; no dictionary words |
| Local device PIN (Windows Hello / Touch ID) | 8 digits or 12-char passphrase     | Not a repeating or sequential pattern               |
| Service account passwords                   | 24 characters                      | Random; generated by 1Password                      |
| API keys / tokens                           | 32+ characters or vendor-generated | Stored in 1Password; never hardcoded in source code |
| Wi-Fi PSK (admin use)                       | 20 characters                      | IT-generated; stored in 1Password vault             |

3.2.1 Passwords must not contain the employee's name, username, company name, or any portion of their email address.

3.2.2 Passwords must not follow predictable patterns (e.g., `Summit2024!`, `Password1`, sequential months).

3.2.3 Passphrases (a random sequence of 4+ unrelated words, e.g., generated by 1Password's passphrase generator) are acceptable where character-based requirements are met.

### 3.3 Password Rotation

3.3.1 Okta passwords expire every **180 days**. Employees will receive Okta-generated email reminders at 14 days and 3 days before expiration.

3.3.2 Service account passwords must be rotated at least every **90 days** or upon any team member departure. Rotation must be performed in 1Password with the updated credential saved before deployment.

3.3.3 Passwords must be changed immediately upon any known or suspected compromise. The employee must notify the IT Service Desk ([servicedesk@summitit.com](mailto:servicedesk@summitit.com) or `#it-help` on Slack) and the Security Operations Center ([soc@summitit.com](mailto:soc@summitit.com)) within one hour of discovery.

3.3.4 Password history enforcement prevents the reuse of the last **12 passwords** for Okta accounts.

3.3.5 Privileged accounts (local admin, Okta admin, AWS IAM privileged roles) must have passwords rotated every **90 days** and stored in a restricted 1Password vault accessible only to authorized IT administrators.

### 3.4 Account Lockout

3.4.1 Okta enforces an account lockout after **5** consecutive failed authentication attempts within a 10-minute window.

3.4.2 Locked accounts are released automatically after 30 minutes or manually by the IT Service Desk upon verification of identity.

3.4.3 Repeated lockout events (3 or more within 24 hours) trigger an automated alert to the Security Operations Center (SOC) for investigation.

### 3.5 Default and Vendor Credentials

3.5.1 All default vendor passwords must be changed before any device or system is placed into service. This includes network equipment, printers, servers, and SaaS admin accounts.

3.5.2 Default credentials discovered on in-service systems must be reported to IT Engineering (L3) immediately and remediated within 48 hours.

### 3.6 Password Sharing and Storage

3.6.1 Passwords must never be shared via email, Slack, Teams, SMS, or any unencrypted channel. Use 1Password's secure share feature if a credential must be temporarily shared with an external party.

3.6.2 Passwords must never be written on paper, whiteboards, sticky notes, or stored in plain-text files, spreadsheets, or documents.

3.6.3 Passwords must never be hardcoded in source code, scripts, configuration files, or CI/CD pipelines. Use secrets management solutions (AWS Secrets Manager, Azure Key Vault, or 1Password Secrets Automation) for automated credential access.

### 3.7 Password Resets

3.7.1 Self-service password reset is available through the Okta End-User Dashboard at <https://summitit.okta.com>. Users must have at least one MFA factor enrolled to use self-service reset.

3.7.2 When identity cannot be verified via self-service, employees must contact the IT Service Desk at +1 (800) 555-7866 or [servicedesk@summitit.com](mailto:servicedesk@summitit.com). Identity will be verified using two identifying factors (employee ID, manager confirmation, or last four of SSN).

3.7.3 IT Service Desk agents must never ask for a user's current password during a password reset interaction. Employees must refuse any such request.

## 4. Roles & Responsibilities

| Role                 | Responsibility                                                                                                              |
|----------------------|-----------------------------------------------------------------------------------------------------------------------------|
| All Employees        | Use 1Password for all credentials; adhere to complexity and rotation requirements; report suspected compromises immediately |
| IT Service Desk (L1) | Process password reset requests; verify identity per procedure; escalate suspicious reset patterns                          |

|                          |                                                                                                       |
|--------------------------|-------------------------------------------------------------------------------------------------------|
| IT Security & Compliance | Own policy; configure Okta password policies; audit compliance; investigate credential incidents      |
| L2 Desktop & Systems     | Manage local admin account credentials; reset service account passwords                               |
| L3 Engineering           | Configure Okta, 1Password, and secrets management integrations; enforce technical controls            |
| All Managers             | Ensure team compliance; promptly notify IT upon team member departure to initiate credential rotation |

## 5. Enforcement & Consequences

---

5.1 Okta enforces technical controls including complexity requirements, history, and lockout as configured by IT Security. These are non-negotiable and apply to all users.

5.2 Policy violations discovered through audits, SOC alerts, or reports will be investigated by IT Security & Compliance in coordination with HR:

- **First violation** (e.g., password stored in a spreadsheet, credentials shared in Slack): Mandatory 1Password training; written warning.
- **Repeat or deliberate violation** (e.g., sharing credentials externally, disabling lockout controls): Formal HR action; access restrictions; escalation to management.
- **Severe violation** (e.g., credential-related breach, unauthorized account creation): Immediate access suspension; HR/Legal investigation; possible termination and legal referral.

## 6. Exceptions

---

Exceptions to specific requirements (e.g., systems that do not support 16-character passwords) must be submitted as a Policy Exception Request through SummitDesk. Exceptions require:

1. Technical justification documenting the limitation.
2. Compensating controls (e.g., stricter MFA, network isolation).
3. Approval from IT Security & Compliance and the system owner.
4. Review every 90 days until the underlying limitation is resolved.

## 7. Related Documents

---

- POL-001 - Acceptable Use Policy
- POL-003 - Multi-Factor Authentication Policy
- POL-009 - Access Control & Least Privilege Policy
- REF-0001 - Summit IT Environment Standards

- 1Password Business Admin Guide (internal wiki)
- Okta Password Policy Configuration (internal wiki)

## 8. Revision History

| Version | Date       | Author                   | Summary of Changes                                                                         |
|---------|------------|--------------------------|--------------------------------------------------------------------------------------------|
| 1.0     | 2020-06-01 | IT Security              | Initial release                                                                            |
| 2.0     | 2022-11-01 | IT Security              | Introduced 1Password Business as mandatory manager; removed standalone LastPass references |
| 2.1     | 2023-05-15 | IT Security & Compliance | Extended service account rotation to 90 days; added secrets management clause              |
| 2.2     | 2024-04-01 | IT Security & Compliance | Raised Okta minimum to 16 chars; aligned to NIST SP 800-63B guidance                       |
| 2.3     | 2025-01-08 | IT Security & Compliance | Added repeated lockout SOC alerting; updated reset identity verification                   |
| 2.4     | 2025-11-20 | IT Security & Compliance | Annual review; added passphrase guidance; clarified API key storage requirements           |